

온프레미스 **LLM** 필요성

의료·법률·금융 데이터의 외부 전송 불가 규제

기업이 온프레미스 **LLM**을 선택할 수밖에 없는 규제·보안 환경과
국내외 실제 사례를 통한 클라우드 **AI**의 위험 분석

AI 기본법·금융 규제 대응 전략

목차

01

클라우드 LLM의 보안 리스크

- 데이터 유출 위험
- 환각 현상의 문제
- 도메인 전문성 부족
- OWASP 10대 취약점

02

실제 기밀 유출 사례

- 삼성전자 ChatGPT 유출
- JPMorgan Chase 대응
- 미래에셋증권 도입
- Amazon·딥시크 사례

03

규제 환경 분석

- 개인정보보호법·AI 기본법
- 금융 망분리 규제
- 의료·법률 비밀유지 의무
- EU AI Act·GDPR

04

온프레미스 LLM의 해결책

- 데이터 주권 확보
- 규제 준수 달성
- 도메인 특화 성능
- 서비스 연속성 보장

05

구축 비용과 현실

- GPU 서버 20~50억 원
- AI 엔지니어 1~2억 원
- 통합 비용 30~40%
- 모델 드리프트 관리

06

sLLM + QLoRA 대안

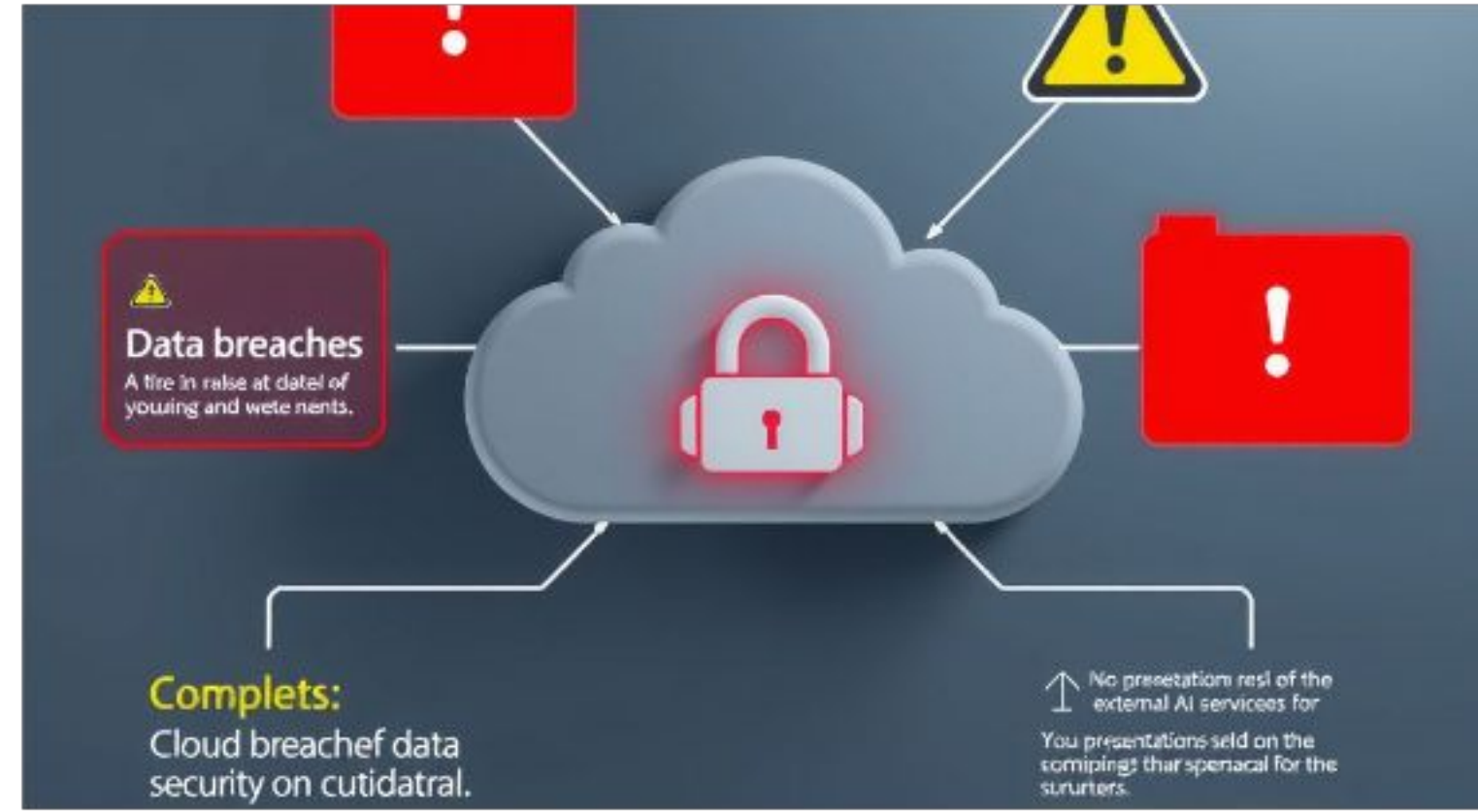
- T4 GPU 1장으로 가능
- 초기 비용 대폭 절감
- 수십 분~수 시간 학습
- 보안과 경제성 양립

학습 목표



규제·보안 환경 이해

- 기업이 온프레미스 LLM을 선택할 수밖에 없는 규제·보안 환경을 이해합니다.
- 의료·법률·금융 분야의 데이터 외부 전송 제한 규제를 파악합니다.
- 온프레미스 도입이 필수인 산업 분야를 구분할 수 있습니다.



클라우드 AI 위험 파악

- 국내외 실제 사례를 통해 클라우드 AI의 위험을 파악합니다.
- 삼성전자, JPMorgan Chase 등의 기밀 유출 사고와 대응 방식을 학습합니다.
- 온프레미스 전환 흐름의 4단계 패턴을 이해합니다.



국내 규제 영향 분석

- 한국의 개인정보보호법·AI 기본법·금융 규제가 온프레미스 도입에 미치는 영향을 설명할 수 있습니다.
- EU AI Act, GDPR 등 글로벌 규제 환경을 이해합니다.
- 산업별 외부 AI 사용 가능 여부를 판단할 수 있습니다.

LLM 배포 방식 3가지



온프레미스

- 회사 데이터센터에 LLM 설치·운영; 사내 서버에 보관·보안 최고



클라우드 기반

- AWS/Azure 등 클라우드에 LLM 배포; 편리하나 유출 위험 존재



온디바이스

- GPT4All/Ollama로 개인 PC 실행; 로컬 보관으로 보안 높음, 기업 적용 한계

클라우드 LLM API의 보안 리스크



데이터 전송·저장 위험

- 사용자가 입력한 데이터가 외부 서버에 전송·저장됩니다.
- AI 학습 데이터로 재활용될 수 있어 기업 기밀이 학습에 포함될 위험이 있습니다.
- ChatGPT, Gemini 등 클라우드 기반 LLM의 본질적인 보안 취약점입니다.



정보 회수 불가능

- 한번 업로드된 정보는 회수·삭제가 불가능합니다.
- 외부 서버에 저장된 데이터에 대한 통제권을 상실합니다.
- 데이터 주권 문제가 발생하며 규제 위반 가능성이 높아집니다.

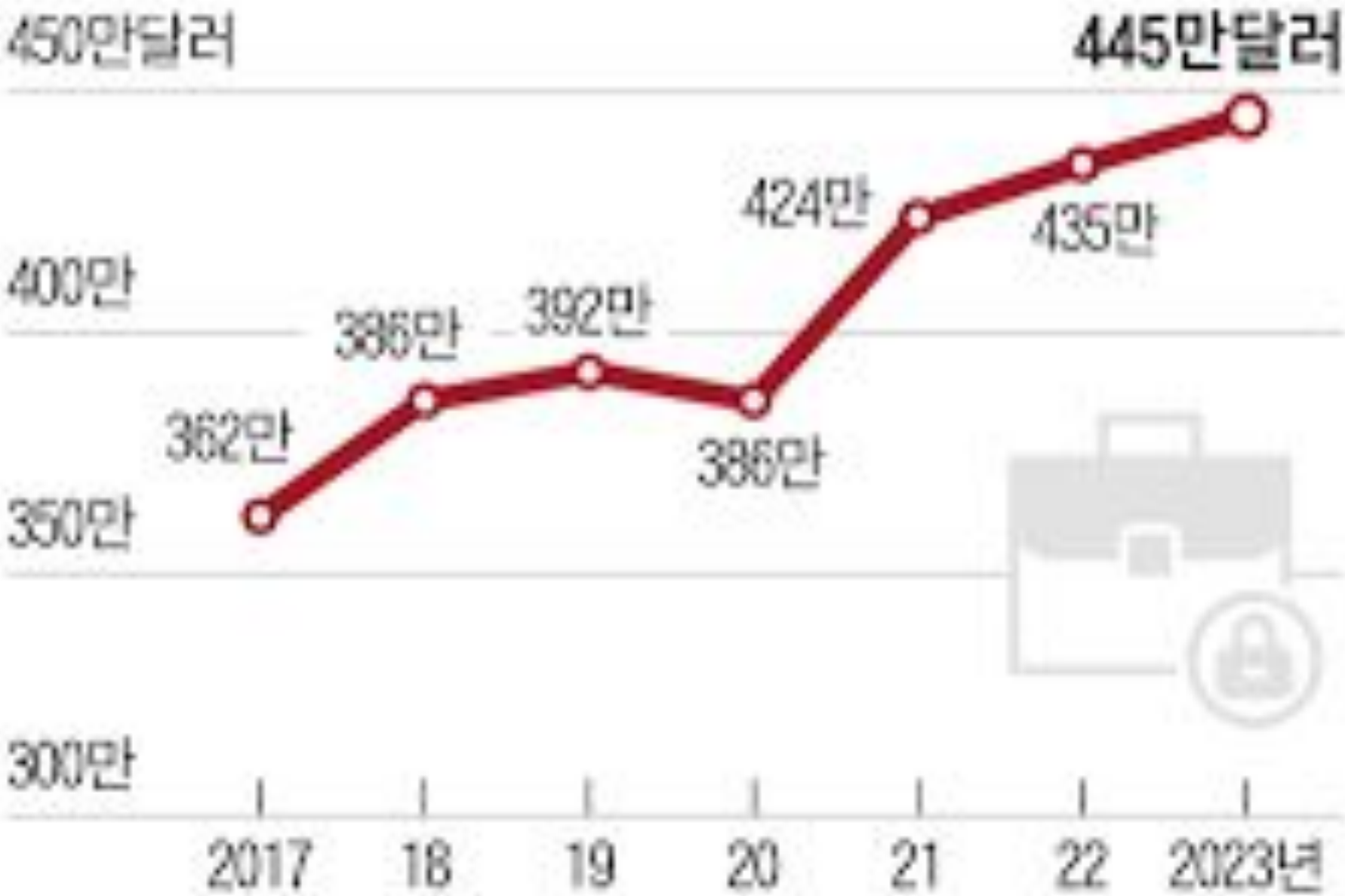


기밀 정보 노출 가능성

- 기업의 핵심 정보가 타인의 질문에 대한 답변으로 노출될 수 있습니다.
- 학습된 데이터가 다른 사용자의 응답에 반영될 위험이 있습니다.
- 경쟁사에게 기술 정보나 영업 비밀이 유출될 가능성이 존재합니다.

3대 핵심 리스크 (1): 데이터 유출

기업 데이터 유출 비용 단위: 달러(미국)



자료-IBM 시큐리티

외부 API 서버의 데이터 재활용 및 해킹 위험

- 외부 API 서버로 전송된 데이터는 학습에 재활용되거나 해킹 위험에 노출됩니다.
- 기업 데이터가 AI 모델 학습에 무단으로 사용될 수 있습니다.
- 해커의 공격 대상이 되어 대규모 데이터 유출 사고로 이어질 수 있습니다.
- 데이터 주권을 상실하고 통제 불가능한 상태가 됩니다.

딥시크 데이터 수집 문제 사례 (2024년 2월)

- 2024년 2월 중국 AI 기업 딥시크의 데이터 수집 이슈가 발생했습니다.
- 한국 외교부·산업통상자원부·카카오 등이 사용을 금지했습니다.
- 외부 AI 서비스의 데이터 주권 리스크가 명확히 드러난 사례입니다.
- 국가 안보 및 기업 기밀 보호를 위한 규제 강화의 계기가 되었습니다.

3대 핵심 리스크 (2): 환각 현상

환각 현상이란?

- LLM이 사실이 아닌 정보를 그럴싸하게 지어내는 현상
- 범용 모델은 회사의 최신 정책이나 제품 스펙을 정확히 알 수 없음
- 단순한 오답이 아니라 실제 피해로 이어질 수 있는 심각한 문제

법률 분야의 위험

- 존재하지 않는 판례를 인용하는 사례 발생
- 미국 Mata v. Avianca 사건 (2023년): 변호사가 ChatGPT가 만든 가짜 판례를 법원에 제출하여 징계
- 비밀유지 의무와 함께 법률 분야에서 가장 위험한 요소

의료 분야의 위험

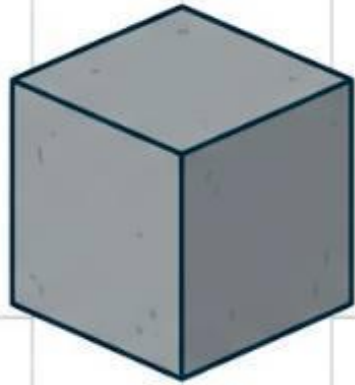
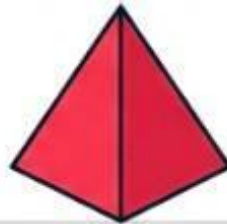
- 잘못된 약물 용량을 제시하여 실제 피해 가능성
- 환자 진료 기록 요약 시 부정확한 정보 생성
- 임상 의사결정 지원에 쓰기엔 신뢰도 부족
- 의료 AI의 안전성 확보가 필수

기업 환경에서의 문제

- 고객 응대나 내부 의사결정에 부적합
- 최신 정보 반영 불가능
- 기업 특화 지식 부족으로 피상적 답변
- 도메인 데이터로 파인튜닝이 필요한 이유

3대 핵심 리스크 (3): 도메인 전문성 부족

LLM의 딜레마: 범용성의 비용 vs 전문성의 한계

거대 범용 모델 (General-Purpose LLMs)	소형 전문가 모델 (Specialized LLMs)
	$\int f(x) dx$  Mathematics <code>def init():</code>  Coding $A \rightarrow B$  Instruction Following
- 모든 도메인에서 우수한 성능 - 훈련 및 배포 비용이 막대함 (Prohibitively Expensive)	- 특정 영역(수학, 코딩)에서 효율적 - 훈련 분포를 벗어나면 일반화 능력 부족 (Struggle to Generalize)

Goal: 여러 개의 작은 전문가 모델을 결합하여, 거대 모델의 성능을 효율적으로 구현.

고도로 전문화된 분야에서의 한계

- 금융 규제, 반도체 공정 등 전문 분야에서 범용 LLM의 답변이 피상적
- 업계 특화 용어와 최신 규제 변경사항을 정확히 반영하지 못함
- 전문가 수준의 의사결정 지원 불가능
- 기업 내부 데이터와 프로세스에 대한 이해 부족

OWASP LLM 10대 취약점

- OWASP가 발표한 'LLM 10대 취약점' 중 핵심 문제
- '학습 데이터 중독': 악의적 데이터가 학습 과정에 포함되어 모델 성능 저하
- '과도한 의존': 검증되지 않은 LLM 출력에 대한 맹목적 신뢰
- 전문 분야에서의 신뢰도 부족 문제를 명확히 지적

국내 사례: 삼성전자 ChatGPT 기밀 유출

사고 개요

- 2023년 3월, ChatGPT 허용 후 20일 내 3건 기밀 유출; 반도체 부문에서 발생; 악의적 해킹 아닌 업무 사용 중 유출

1건 사고

- 반도체 설비 계측 DB 소스 코드 입력
- 오류 확인을 위해 ChatGPT에 직접 입력
- 핵심 기술 정보 외부 유출

2건 사고

- 수율·불량 관련 프로그램의 테스트 시퀀스 입력
- 최적화를 위해 ChatGPT 활용
- 생산 공정 정보 노출

3건 사고

- 내부 회의 녹음을 음성 전사
- ChatGPT에 입력하여 회의록 생성
- 경영 기밀 정보 유출

핵심 교훈

- 편리하니까 그냥 쓰다가 가장 위험한 보안 구멍
- 직원의 일상 업무에서 데이터 유출 발생
- 외부 해커보다 내부 사용이 더 위험

국내 사례: 삼성전자의 대응과 교훈

즉각적 대응

- 사내 **ChatGPT** 사용 즉시 금지 조치
 - 전사적 보안 정책 강화
 - 외부 **AI** 도구 사용 제한
 - 임직원 보안 교육 실시

자체 AI 모델 개발

- 자체 **AI** 모델 '**Samsung Gauss**' 개발
 - 사내 전용으로만 운영
 - 기밀 정보가 외부로 나가지 않는 구조
- 온프레미스 환경에서 안전하게 활용

핵심 교훈

- 데이터 유출은 외부 해커가 아니라 직원의 일상 업무에서 발생
 - 편리하다고 그냥 쓰는 것이 가장 위험한 보안 구멍
 - 업무 효율성과 보안의 균형 필요
- 사전 예방이 사후 대응보다 중요

온프레미스 전환의 의미

- 사고 후 전환이 아닌 처음부터 온프레미스로 시작하는 기업 증가
 - 데이터 주권 확보의 중요성
 - 규제 준수와 보안을 동시에 달성
- 기업용 **AI**의 새로운 표준

미래에셋증권 온프레미스 sLLM 도입

도입 배경

- 금융 규제를 준수하면서 AI 전환을 달성하기 위한 노력
- 고객 금융정보의 외부 전송 불가 규제
- 망분리 환경에서의 AI 활용 필요성
- 보안과 혁신의 균형점 모색

도입 솔루션

- 네이버클라우드의 '하이퍼클로바X 대시'를 온프레미스 환경에 도입
- 사내 서버에서만 데이터 처리
- 외부 전송 없이 AI 기능 활용
- 금융권 특성에 맞춘 맞춤형 구축

금융권 최초 사례

- 금융권 최초 온프레미스 sLLM 도입 사례
- 규제 준수와 AI 혁신의 성공적 결합
- 다른 금융기관의 벤치마크 대상
- 금융권 AI 도입의 새로운 모델 제시

온프레미스 선택 이유

- 외부 전송 금지로 온프레미스 필수
- 금융위 AI 가이드라인 준수·데이터 주권 확보
- 감사 추적 가능·서비스 연속성 확보

해외 사례: JPMorgan Chase LLM Suite

기본 정보

- 세계 최대 은행의 자체 LLM 구축
- 외부 AI 도구(ChatGPT 등) 업무 사용 금지
- 완전 자체 개발 및 운영

사용 규모

- 약 25만 명 직원 접근 가능
- 일일 약 12.5만 명이 활용
- 전사적 AI 활용 체계 구축

핵심 기능

- 문서 요약 및 투자 메모 작성
- 리서치 분석 지원
- 프레젠테이션 자동 생성
- 업무 생산성 대폭 향상

수상 내역

- American Banker 2025 Innovation of the Year 수상
- 금융권 AI 혁신 사례로 인정
- 글로벌 벤치마크 대상

도입 이유

- 데이터 유출 방지가 최우선
- 금융 데이터의 외부 전송 자체가 규제 위반
- 규제 준수 필수

해외 사례: Amazon과 딥시크

Amazon ChatGPT 사용 제한

- ChatGPT 응답에서 자사 내부 데이터와 유사한 출력 발견
- 2023년 보안 위험 인지 후 즉시 사용 제한 조치
- 외부 AI 서비스의 학습 데이터 재활용 위험 확인

직원 대상 경고 조치

- 직원들에게 코드와 기밀 정보를 챗봇에 입력 금지 경고
- 내부 보안 정책 강화 및 교육 실시
- 대체 솔루션 검토 시작

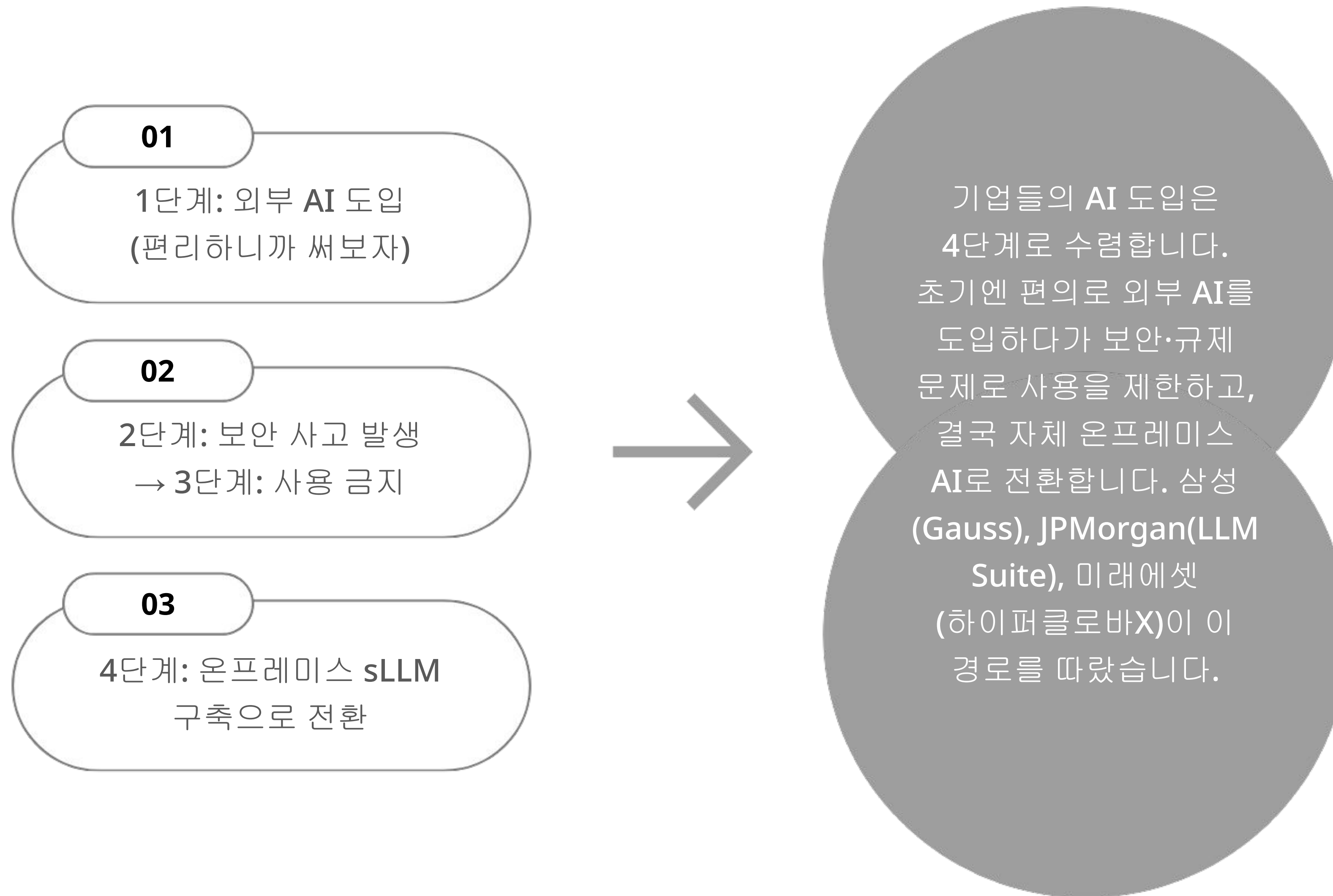
딥시크 데이터 수집 문제

- 중국 AI 기업 딥시크의 데이터 수집 이슈 발생
- 한국 외교부, 산업통상자원부 사용 금지
- 카카오 등 주요 기업도 사용 중단 결정

데이터 주권 리스크

- 외부 AI 서비스 사용 시 데이터 주권 상실 위험
- 국가별 데이터 보호 규제 충돌 가능성
- 기업 기밀이 타국 서버에 저장되는 리스크

기업 대응 패턴: 4단계 전환



한국 규제 환경 개요

개인정보보호법

- 개인정보의 외부 전송·저장 시 정보주체 동의 필수
- 고유식별정보(주민번호 등) 유출 시 강력한 제재
- 전 산업에 적용되는 기본 규제

인공지능기본법

- 2026년 1월 시행 예정
- AI 시스템의 투명성·설명가능성 요구
- 고위험 AI에 대한 관리 의무 부과



'세계 최초 시행' AI기본법 주요 내용

2026년 1월 22일 시행



산업기반조성

- **인공지능기본계획 수립**: 과학기술정보통신부장관이 3년마다 수립
- 국가인공지능위원회 실효성 확보, AI 안전연구소 설립 등

'고영향 AI' 개념 도입

- **고영향 AI**: 의료·에너지·채용·대출심사 등 국민의 생명이나 권리에 큰 영향을 주는 분야의 AI
- 고영향 AI 이용한 제품·서비스 제공 시 이용자에게 **사전 고지 필요**
- 안전성 관리 의무, 과태료 부과 책임 등 법적 규제 대상

AI 투명성 확보

- **AI 워터마크 표시 의무**: 생성형 AI 활용한 결과물에 이용자가 AI 제작물임을 알 수 있도록 가시적·비가시적 워터마크 부착 등 표시

해외 빅테크 국내 대리인 지정

- 전년도 글로벌 매출액 1조 원 이상, 국내 AI 서비스 매출 100억 원 이상, 국내 일평균 이용자 100만 명 이상 조건 중 **하나라도 해당 시 국내 대리인 지정**
- 현재 **오픈AI·구글** 해당

과태료 부과

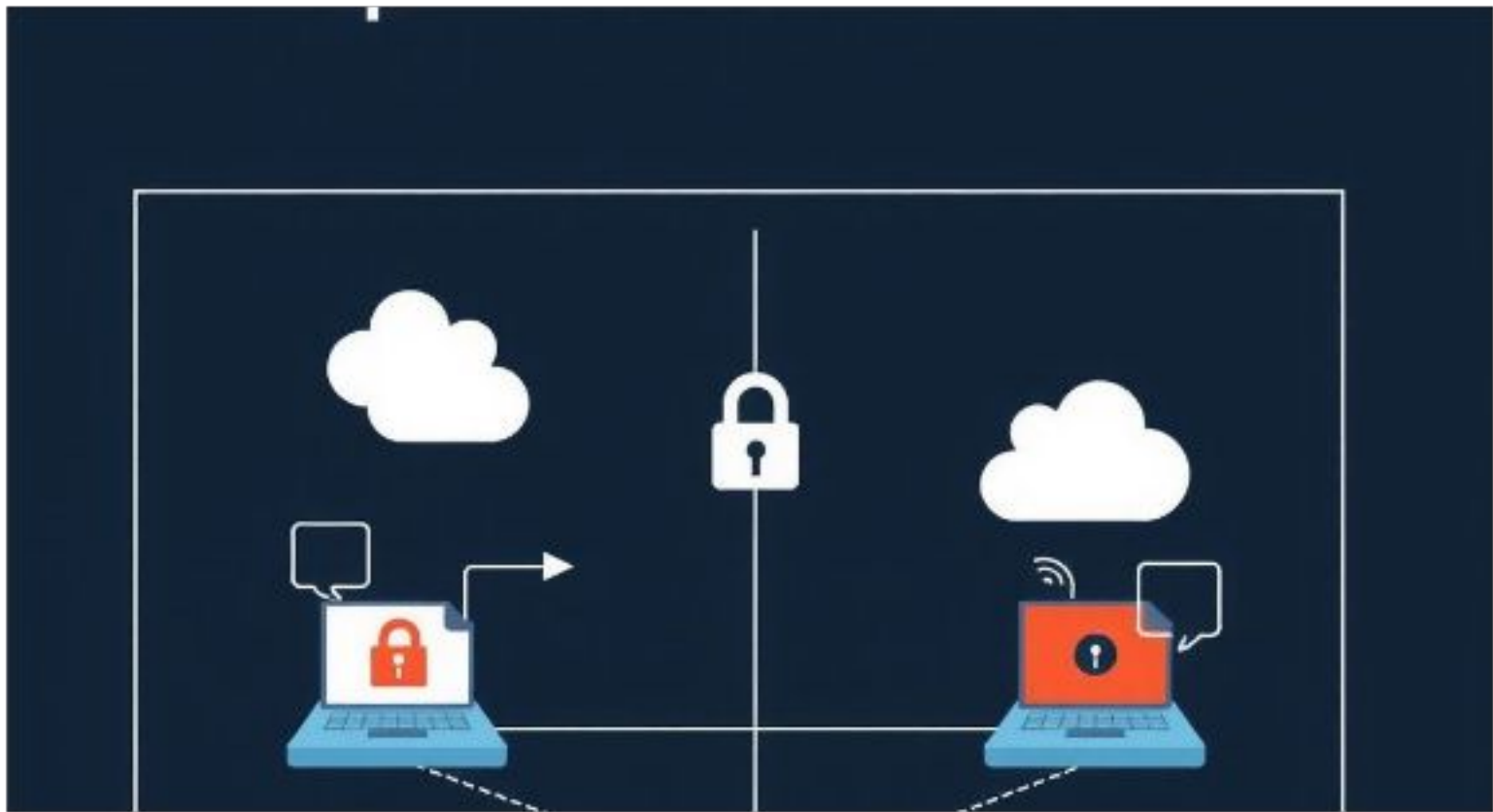
- AI 기본법상 의무 위반 시 **최대 3,000만 원** 과태료 부과, 1년 이상 계도기간 운영

금융 규제: 망분리와 AI



AI 가이드라인

- 금융위원회 AI 활용 7대 원칙 적용
- 거버넌스, 합법성, 보조수단성 준수
- 신뢰성, 금융안정성, 신의성실 요구
- 보안성 확보 의무



망분리 규제

- 내부 업무망과 인터넷망의 물리적·논리적 분리 의무
- 고객 금융정보의 외부 전송 엄격히 제한
- 금융권 특성상 가장 엄격한 보안 요구



완화 로드맵

- 2024년: 규제 샌드박스로 제한적 허용
- 2025년: 보안 검증 전제 SaaS 허용
- 2026년: 자율보안 책임 강화
- 고객 데이터 외부 전송은 여전히 제한

의료 규제: 환자 데이터 보호

의료법 제21조

- 환자 진료기록의 외부 제공 시 환자 동의 필수
- 의료 데이터의 외부 전송 엄격히 제한
- 위반 시 법적 제재 및 의료기관 책임

개인정보보호법

- 건강정보는 민감정보로 분류
- 별도 동의 및 안전조치 의무 부과
- 의료 데이터 처리 시 가장 높은 보안 수준 요구

생명윤리법

- 인체유래물·유전체 정보의 목적 외 사용 금지
- 연구 목적 사용 시에도 엄격한 승인 절차
- 익명화 처리 의무

의료 AI의 딜레마

- AI가 가장 큰 가치를 발휘할 수 있는 데이터가 정확히 가장 밖으로 내보낼 수 없는 데이터
- 진료기록, 영상, 유전체 정보 등
- 온프레미스 sLLM이 유일한 현실적 해결책

법률 규제: 비밀유지 의무

변호사법 제26조

- 직무상 알게 된 비밀 누설 시 형사처벌
- 2년 이하 징역 또는 1천만 원 이하 벌금
- 변호사 자격에 대한 징계 가능
- 가장 엄격한 비밀유지 의무

변호사 윤리장전

- 의뢰인 정보의 비밀유지는 변호사의 가장 기본적 의무
- 법률사무소 보안 규정 준수 필수
- 의뢰인 사건 정보의 외부 시스템 입력 시 사전 동의 필요

외부 AI 사용 위험

- 외부 **AI**에 의뢰인 사건 내용 입력은 비밀유지 의무 위반 가능
- 의뢰인의 명시적 동의 없이는 **ChatGPT** 사용 자체가 징계 사유
- 법률 데이터의 온프레미스 처리 필수

법률 도메인 선택 이유

- 보안 요구가 가장 높은 분야
- 전문 용어·판례 인용의 정확성 필수
- 범용 **LLM**의 환각이 가장 위험한 분야
- **sLLM** 파인튜닝 필요성을 가장 잘 보여주는 도메인

글로벌 규제: EU AI Act와 GDPR

EU AI Act (2025년 8월 본격 시행)

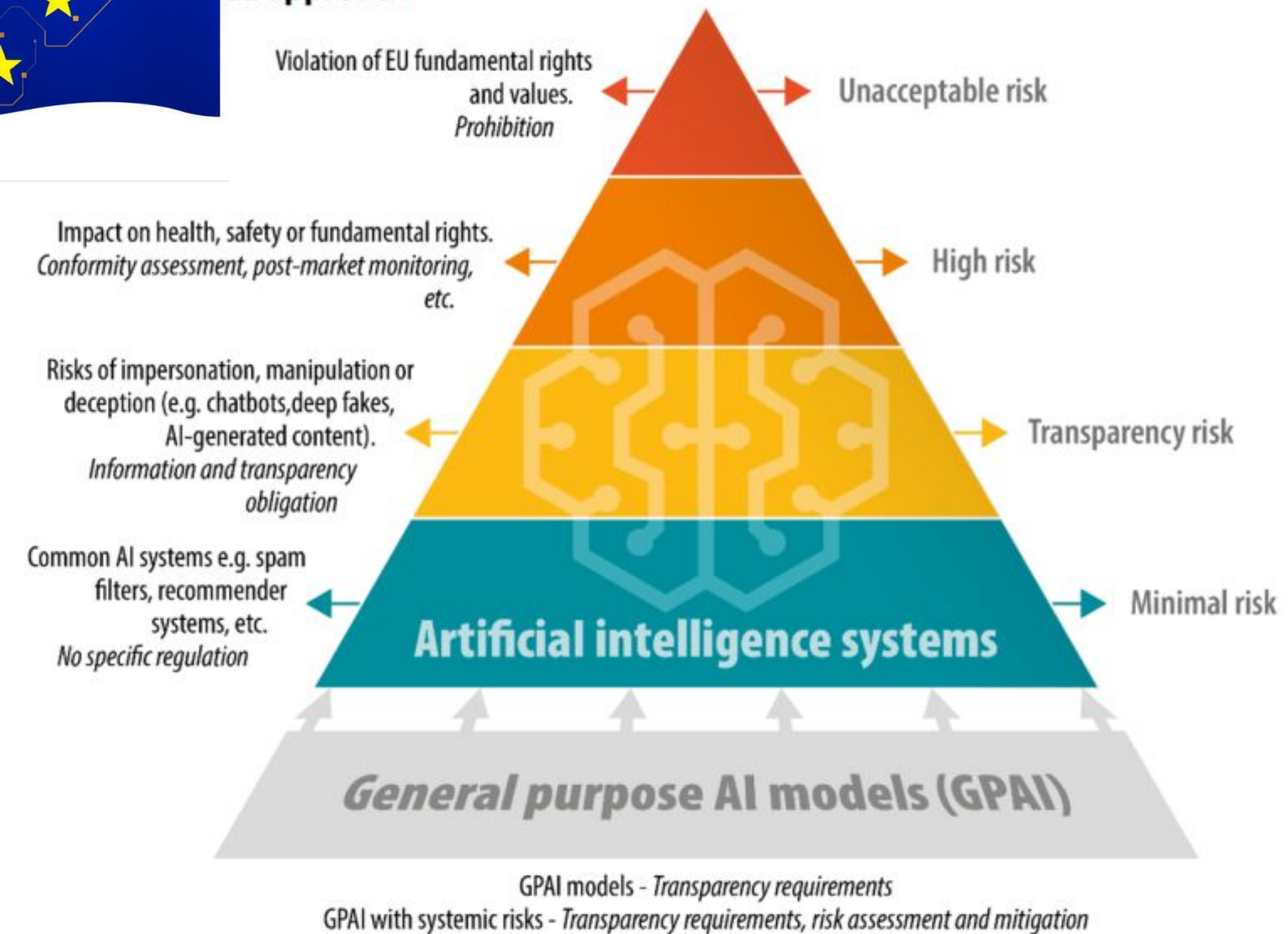
- 고위험 AI 시스템에 대한 투명성·품질관리 의무 부과
- 제재 수준: 최대 3,500만 유로 또는 글로벌 매출 7%
- EU 내에서 사용되는 모든 AI 시스템에 적용



EU GDPR

- 개인정보 목적 제한·최소 처리 원칙 적용(학습데이터 포함)
- 제재: 글로벌 매출의 4%
- 데이터 주권·보안 강화를 지향

Proportioned approach



Data source: [European Commission](#)

산업별 외부 AI 사용 가능 여부

금융

- 외부 **API**: 금지
- 전용 클라우드: 조건부 허용
(망분리 완화 후)
- 온프레미스: 권장
- 고객 금융정보 외부 전송
엄격히 제한
- 현실적 선택: 온프레미스

의료

- 외부 **API**: 금지 (민감정보)
- 전용 클라우드: 조건부
(익명화 전제)
- 온프레미스: 권장
- 환자 진료기록 외부 제공 시
동의 필수
- 현실적 선택: 온프레미스

법률

- 외부 **API**: 의뢰인 동의 필요
- 전용 클라우드: 조건부
- 온프레미스: 권장
- 비밀유지 의무 위반 위험
- 현실적 선택: 온프레미스

공공·군사

- 외부 **API**: 금지
- 전용 클라우드: 금지
- 온프레미스: 필수
- 비밀·대외비 문서 외부 처리
금지
- 유일한 선택: 온프레미스

온프레미스 LLM이 해결하는 6가지 문제

1. 데이터 유출 위험 차단

- 모든 데이터가 사내 서버에서만 처리되어 외부 전송 원천 차단
- 해킹 위험 및 학습 데이터 재활용 방지
- 기업 기밀 정보의 완전한 통제 가능
- 삼성전자 사례처럼 업무 중 유출 사고 예방

2. 규제 준수 부담 해소

- 데이터 주권 확보로 개인정보보호법·AI 기본법 준수
- 접근 권한 제어 및 감사 로그 기록으로 투명성 확보
- 금융·의료·법률 분야의 엄격한 규제 요건 충족
- EU AI Act, GDPR 등 글로벌 규제 대응 용이

3. 공급업체 종속 탈피

- 오픈소스 모델(LLaMA, EXAONE 등) 활용으로 벤더 의존도 감소
- 외부 서비스 장애·정책 변경·가격 인상에 독립적
- 서비스 연속성 보장 및 장기적 비용 절감
- 자체 AI 인프라 구축으로 기술 주권 확보

4. 도메인 특화 성능 확보

- 사내 데이터로 파인튜닝하여 업무 맞춤형 AI 구축
- 도메인 데이터로 파인튜닝하여 정확도 향상 및 환각 위험 감소
- 출력 필터링 가능으로 신뢰도 높은 답변 제공
- 회사의 최신 정책·제품 스펙 정확히 반영

온프레미스 LLM 구축의 숨겨진 비용 (1)



인프라 비용: GPU 서버 구축

- GPU 서버만 최소 20억~50억 원 투자 필요
- 프로토타입에서 프로덕션 전환 시 비용이 8~12배 증가



기업은행 사례

- 사내 GPT 구축을 위해 초기 약 20억 원 투자
- 2차로 추가 30억 원 투자하여 총 50억 원 규모



규모별 월간 운영 비용

- 중소 규모(PoC·파일럿): 월 약 58만~218만 원
- 대규모(프로덕션): 월 290만 원 이상

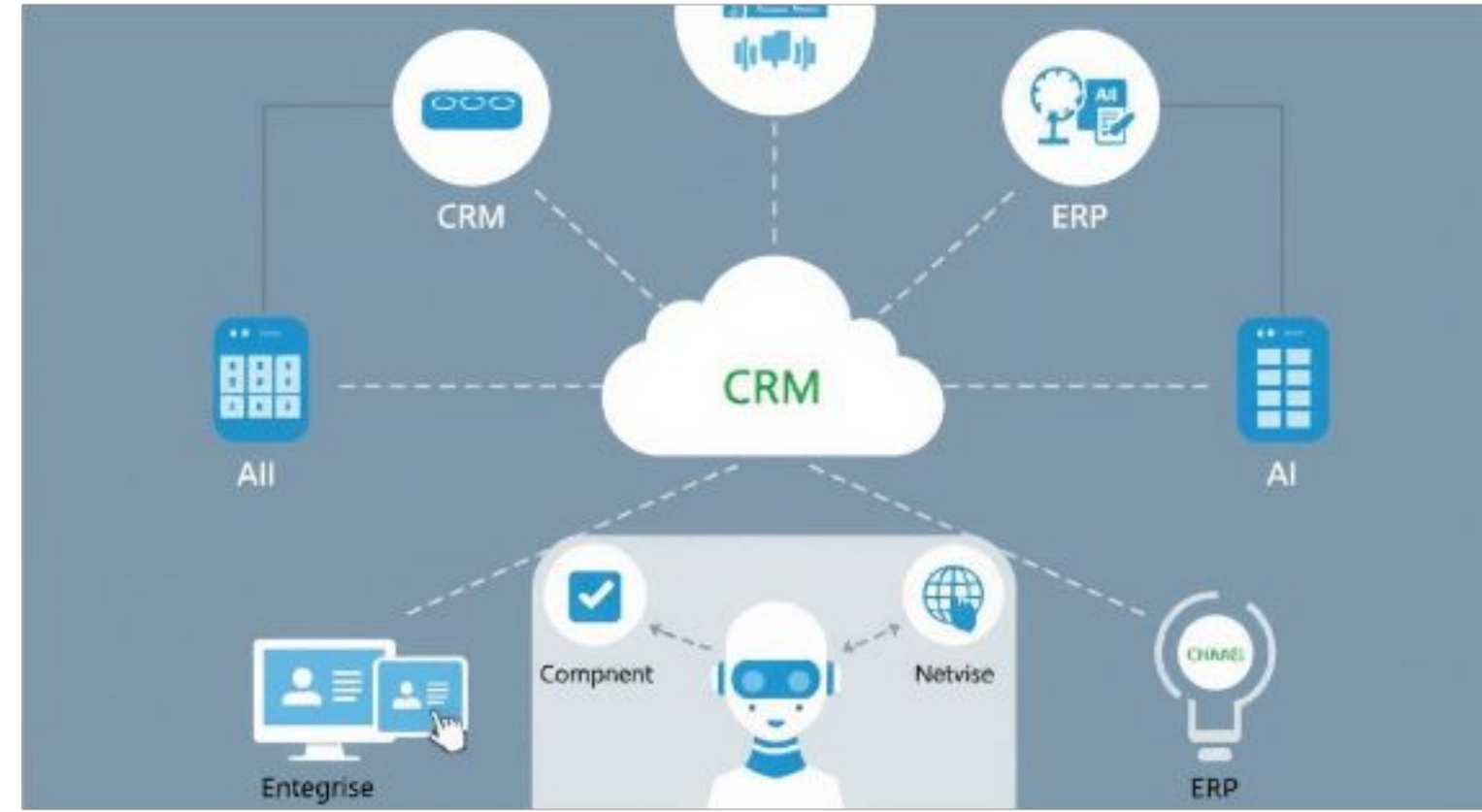
온프레미스 LLM 구축의 숨겨진 비용

(2)



인재 비용

- AI 엔지니어 연봉: 인당 약 1~2억 원 (대리급 4년차 이상)
- 전문가 채용·유지 자체가 어려움
- ML 엔지니어 팀 구성 필수
- 지속적인 교육 및 인력 관리 비용 발생
- 인재 확보 경쟁 심화로 비용 증가 추세



통합 비용

- 전체 예산의 30~40% 차지
- CRM, ERP 등 기업 시스템과의 연동 작업이 복잡하고 비쌈
- API 버전 불일치 (3~12개월마다 변경)
- 데이터 스키마 충돌 및 서드파티 업데이트 의존성
- 통합 작업의 복잡도가 예상보다 훨씬 높음



운영 비용

- 모델 드리프트: 배포 후 30~90일 내 성능 저하 시작
- 재학습 비용: 연간 초기 비용의 15~25%
- 모니터링·프롬프트 튜닝·QA 검증 비용 추가
- 지속적인 성능 관리 및 유지보수 필요
- 기업용 LLM 프로젝트의 70~85%가 실패하는 주요 원인

온프레미스 LLM 구축의 숨겨진 비용

(3): 운영



모델 드리프트

- 시간이 지나면 성능이 떨어지는 현상
- 배포 후 30~90일 내 시작되며 지속적인 모니터링 필요



재학습 비용

- 연간 초기 비용의 15~25% 소요
- 모니터링·프롬프트 튜닝·QA 검증 비용 추가 발생



프로젝트 실패 요인

- 기업용 LLM 프로젝트의 70~85%가 실패
- 보이지 않는 운영 비용이 주요 원인

현실적 대안: sLLM + PEFT (QLoRA)



대형 LLM 온프레미스

- 필요 GPU: A100 80GB × 4~8장
 - 초기 인프라: 20~50억 원
 - 학습 시간: 수일~수주
- 전문 인력: ML 엔지니어 팀 필수
 - 재학습 비용: 수천만 원/회
- 높은 진입 장벽과 유지 비용
 - 대규모 조직에 적합
 - 장기적 투자 필요



sLLM + QLoRA

- 필요 GPU: T4 15GB × 1장으로도 가능
 - 초기 인프라: 수백만~수천만 원
 - 학습 시간: 수십 분~수 시간
- 전문 인력: 이번 과정 수료 수준으로 가능
 - 재학습 비용: Colab 무료~수만 원/회
- 낮은 진입 장벽과 유지 비용
 - 중소 규모 조직에 적합
 - 빠른 실험과 배포 가능

핵심 요약

클라우드 AI는 편리하지만 기밀 유출 사고가 반복됩니다.

한국·EU 규제는 데이터 주권과 보안 강화 방향입니다.

금융·의료·법률·공공 분야에선 온프레미스가 현실적 대안이고,
sLLM+QLoRA로 비용을 크게 줄여 실무적 도입이 가능합니다.
